Estado del arte: «Mind the Gap»

Medida activa a gran escala del despliegue de TLS postcuántico y qué deja sin cubrir

Pablo Marugán Bastante · GITST, EPS-UAM · Tutor: Jorge E. López de Vergara | **04/11/2026** | Tutoría del miércoles 04/11/2026

1. Referencia

N. Wickramasinghe, F. Li, S. Jha y A. Shaghaghi (UNSW Sydney y Georgia Tech), **«Mind the Gap: Policy vs Reality in Post-Quantum TLS Deployment»**, arXiv:2607.29005v1, 31/07/2026. Recomendado por el tutor para el estado del arte.

> **IDEA PRINCIPAL**
>
> Primer estudio **longitudinal** de adopción de TLS postcuántico: más de **2000 millones de handshakes** contra el **top 1 millón** de dominios desde **11 puntos de medida** en tres rondas (julio 2025, noviembre 2025, marzo 2026). Concluye que el despliegue converge en un único híbrido, **X25519MLKEM768**, que lo empujan los **proveedores de infraestructura** (CDN) y no las políticas nacionales, y que no añade latencia apreciable.

2. Método

- **Activo y del lado del servidor:** cliente propio solo TLS 1.3 con soporte PQC nativo, que se conecta a cada dominio. Combina un handshake «sin restricciones» (qué elige el servidor por defecto) con sondas que fijan un parámetro y recorren los demás para mapear lo que soporta.
- **Medida de latencia emparejada:** cada handshake PQ con su equivalente clásico (X25519MLKEM768 frente a X25519), cinco pares por configuración.
- **Atribución:** clasifica cada dominio como gestionado por infraestructura (CDN, nube) o por su propietario, con rangos IP, CNAME, PTR, WHOIS y AS.
- **Encuesta de políticas:** compara las hojas de ruta de Australia, Canadá, UE, Francia, Alemania, India, Reino Unido y EE. UU.

3. Resultados principales

Aspecto	Resultado
Adopción por defecto de X25519MLKEM768	31,3 % (jul. 2025) → 47,4 % (nov. 2025) → **49,2 %** (mar. 2026)
Otros grupos (mar. 2026)	Nunca elegidos por defecto. Soporte: SecP256r1MLKEM768 5,5 %, SecP384r1MLKEM1024 1,95 %, ML-KEM-1024 puro 0,66 %. El 88,8 % de los dominios con PQ solo soporta X25519MLKEM768
Firmas PQ	Ninguna negociada en ninguna ronda
Quién despliega	93,9 % de los despliegues PQ gestionados por infraestructura; Cloudflare y Fastly suman casi el 70 %. Más del 75 % de los dominios de CDN tiene PQ, frente a menos del 10 % de los gestionados por su dueño
Sectores (mar. 2026)	Comercio electrónico ~68 %, finanzas 59 %, sanidad 51 %, **gobierno 38 %**, mensajería 27 %
Políticas frente a realidad	Los países con plazos más tempranos (2030–31) tienen *menos* adopción (32,4 %) que los de plazo 2035 (45,7 %). Dentro de Cloudflare o entre dominios propios no hay diferencia: la explica la composición de la infraestructura, no la política
Latencia	Diferencia mediana **0 ms** (rango intercuartílico −5 a +5 ms). El híbrido añade ~1176 B del cliente y ~1088 B del servidor
Convivencia con lo antiguo	En proveedores, los dominios con PQ admiten más a menudo TLS 1.0/1.1 (18,0 % frente a 14,7 %) y cifrados obsoletos (73,6 % frente a 49,9 %)

4. Encaje con el TFG

Lo que el paper no cubre (según el propio paper o su método)	Lo que aporta la sonda pasiva
Mide **servidores** desde fuera; no observa clientes	Clasifica los **clientes** reales de una red, que es la mitad de la patente
Solo top 1M público; excluye **intranets**, VPN y redes empresariales (lo declara como limitación)	Ve el tráfico de cualquier red donde se instale, incluidos servidores internos y no indexados
Mide qué elige el servidor «por defecto». **No indica** qué grupos mandaba en `key_share` frente a `supported_groups`, ni si probó el **HelloRetryRequest**	Distingue el servidor que **fuerza PQ** con HRR del que acepta clásico: el caso del **45 %** medido en la tutoría 1, invisible con su metodología
Solo HTTPS	Cualquier puerto con TLS (opción `-p`; ampliable)
Puntos de medida en la nube, rutas bien provistas	Tráfico real de la red observada

Con la patente: el paper equivale al **modo activo** (paso a2 de la reivindicación 2, línea del TFG de Roberto Sanz). La sonda cubre el **modo pasivo** (a1), y la patente prevé el modo híbrido precisamente porque cada uno ve lo que el otro no.

> ★ PARA COMENTAR EN LA TUTORÍA
>
> El paper mide servidores, desde fuera y en el top 1M, y deja explícitamente fuera las redes internas y los clientes: es justo el hueco de una sonda pasiva. Además, al medir solo la elección «por defecto» no puede ver si un servidor **fuerza** PQ o se conforma con clásico cuando el cliente no manda la clave, que es lo que mide el 45 % de la tutoría 1 y lo que distingue la sonda. Dato útil para la introducción: en marzo de 2026, casi la mitad del top 1M ya negocia X25519MLKEM768, pero el sector **gobierno** se queda en el 38 % y lo gestionado por el propio dueño en menos del 10 %.

5. Para la memoria

- Citar en la introducción (contexto de adopción y la convergencia en X25519MLKEM768) y en el estado del arte (medida activa frente a pasiva).
- Detalle a tener en cuenta: el texto habla de «ocho países» pero la tabla incluye la UE como región. España no aparece en la encuesta de políticas.
- Otros trabajos localizados para revisar: arXiv:2605.02978 (observabilidad pasiva frente a activa de PQ-TLS, con código público), arXiv:2608.02147 (despliegue PQ-TLS por sectores en Reino Unido) y Holz et al., *The era of TLS 1.3* (metodología activa y pasiva).